SOLUTION ARCHITECTURE

Customer Digital Portal (PRJ-101) | Fictional enterprise case study | Version 1.0 | 23 October 2026

1. Purpose and Design Principles

This document describes a conceptual architecture for a secure customer self-service portal. It is a synthetic training artifact, not a production-ready design. Final technology choices require enterprise standards, threat modelling, performance targets, and stakeholder approval.

Design principles: API-first integration; least privilege; privacy by design; observable services; resilient failure handling; accessible customer journeys; and human approval for material operational decisions.

2. Logical Architecture

Layer	Responsibilities	Controls / Notes
Customer experience	Responsive web portal; journey navigation; validation and error messages.	Accessibility checks; secure session handling; no sensitive data in client logs.
Identity and access	Enterprise identity provider; authentication; role and session claims.	Least privilege; short-lived tokens; secure secrets; audit privileged access.
API / integration	API gateway or integration layer; request validation; rate limits; contract enforcement.	Allow-listed destinations; schema validation; timeout and retry policy; correlation IDs.
Business services	Customer profile and case-status services backed by approved systems of record.	Authorisation at service boundary; avoid direct browser access to internal systems.
Observability	Metrics, logs, traces, alerting, and operational dashboards.	Redact personal data; retain logs per policy; test alert/runbook response.

3. High-Level Request Flow

1. Customer opens the portal and authenticates with the approved identity provider.
2. Portal requests only the data needed for the selected journey.
3. Integration layer validates the request, authorises access, and calls approved backend APIs.
4. Backend service returns the permitted customer or case-status data.
5. Portal renders the result with safe error handling if a dependency is unavailable.
6. Monitoring records operational events while minimising or redacting personal information.

4. Key Interfaces and Data

Interface	Purpose	Key consideration
Identity provider	Authenticate user and provide claims.	Token validation, expiry, session revocation.
Customer profile API	Retrieve approved profile fields.	Field minimisation and record-level authorisation.
Case-status API	Retrieve status and permitted milestone data.	Freshness, ownership, access checks, timeout handling.
Monitoring service	Collect health and reliability telemetry.	Redaction, retention, access control.

5. Security and Privacy

• Use least-privilege identities and service-to-service authentication; never embed secrets in source code.

• Validate input schemas and enforce authorisation on the server for every protected resource.

• Use approved encryption in transit and at rest; manage keys and secrets through approved enterprise services.

• Log security-relevant events with correlation IDs; avoid logging credentials, tokens, or unnecessary personal data.

• Threat-model abuse cases including broken access control, injection, replay, dependency compromise, and denial of service.

6. Reliability and Operations

Define availability and recovery objectives before production. Apply timeouts, bounded retries with backoff, circuit breaking where appropriate, health checks, dashboards, alerts, and documented rollback. Test degraded dependency behaviour and recovery.

7. Decisions and Trade-offs

Decision area	Initial direction	Trade-off / open point
Integration	API-first, approved interfaces	Requires API ownership and contract stability

Decision area	Initial direction	Trade-off / open point
Access control	Identity provider + server-side authorisation	More implementation work; essential for protection
Observability	Central metrics, logs and traces	Cost and retention must follow policy
Deployment	Automated pipeline with release gates	Requires test evidence and rollback rehearsal

8. Open Questions and Approval

Open questions include the approved cloud landing zone, target availability, performance thresholds, data retention period, and exact identity/API standards. This conceptual architecture requires review by the Solution Architect, Security, Privacy, Operations, and Business Owner before production use.

Training note: All project names, dates, people, budgets, and status values in this pack are fictional.